

Law on Personal Data Protection

Personal Data Protection Law

Personal Data Protection Act (PDPA)
B.E. 2562 (2019)

- Personal Data Protection Act (PDPA)
- Officially became effective on June 1, 2022

The General Data Protection Regulation
(GDPR)

- European Union (EU)

Definition of Personal Data

Information about a person that can identify that person either directly or indirectly, but does not include information specifically about deceased persons

- Can directly identify a person (Identified)

- Can indirectly identify a person (Identifiable)

Note: Person means a natural person

Sensitive Personal Data (Section 26)

Sensitive data includes information about:

- *Racial or ethnic origin*
- *Political opinions*
- *Religious or philosophical beliefs*
- *Sexual behavior*
- *Criminal records*
- *Health data*
- *Disability*
- *Trade union data*
- *Genetic data and biometric data*
- *Any other data as prescribed by the Committee*

Personal Data Protection Law

Governs the Processing of Personal Data

- *To what extent can we process personal data?*
- *How can we legally process personal data?*

Note: Processing of personal data means the collection, use, and disclosure of personal data

Persons Related to the Law

Data Subject

- Person who has legal rights and whose data can identify them either directly or indirectly

Data Controller

- Natural person or juristic person who has the power to make decisions regarding the collection, use, or disclosure of personal data

Data Processor

- Natural person or juristic person who collects, uses, or discloses personal data according to the orders or on behalf of the data controller
- Note: A person who performs such operations is not a data controller and therefore is not required to comply with the duties prescribed by law for data controllers

Activities Not Under PDPA (Section 4)

- Processing of personal data "for personal benefit" or "for family activities" of that person
- Operations of government agencies responsible for state security / public safety / anti-money laundering / cybersecurity
- Mass media activities (in accordance with professional ethics)
- Court proceedings and judgments
- etc.

Processing of Personal Data

Principle: The collection, use, and disclosure of personal data must only be supported by legal bases, otherwise it cannot be done

Legal Bases for Processing Personal Data

- Section 24 in conjunction with Section 27

Legal Bases (Lawful Basis)

Principle: Consent Basis

Exceptions where personal data can be collected without consent

- Historical documentation, archiving, research or statistics (Archiving or research)
- To prevent or suppress dangers to life, body, or health of persons (Vital Interest)
- Necessary for the performance of a contract (Contract)
- Necessary for the performance of tasks for public interest or exercise of official authority (Public Task)
- Necessary for legitimate interests of the data controller or other persons or juristic persons (Legitimate Interest)
- Compliance with law (Legal Obligations)

Note: Contract vs. Consent Basis

Contract

- *Necessary for entering into a contract*
- *Address for product delivery / email for sending receipts*
- *Credit card information for hotel booking*

Consent

- *Choice of the data subject*
- *Email for sending newsletters*
- *Credit card information that users choose to save on websites for convenience in future payments*

Legal Conditions for Requesting Consent (Section 19)

- Must be requested before or during collection
- Must be made explicitly
- Must inform of the purpose
- Must be clearly separated from other messages
- Must use formats or text that are easily accessible, understandable, and written in simple language
- Must not be a condition for service provision

Consent can be withdrawn at any time once given. Withdrawal must not be more difficult than giving consent. If withdrawn, the impact must be notified

Note: Consent requests that do not comply with these principles are not binding on the data subject

Note: Legal Obligations vs. Public Task Basis

Legal Obligations

- *Data controllers comply with existing legal requirements*
- *Company reports employee salary information to the Revenue Department*
- *Financial institutions send suspicious transaction data to the Anti-Money Laundering Office*

Public Task

- *Government officials perform duties to achieve public missions*
- *Revenue Department processes salary data*
- *Anti-Money Laundering Office processes suspicious transaction data for further investigation*

Note: Legitimate Interest Basis

High risk, should be used only when other bases are not applicable

Must be used only as necessary (minimize usage)

Legitimate Interest Assessments

- Expectation of the data subject (Expectation)
- Risk
- Safeguard measures

Examples include installing CCTV cameras in companies, customer identity verification to prevent fraud, employee work information, taking photos of activities for public relations purposes, etc.

Rights of Personal Data Subjects

- Right to be informed
- Right to access personal data
- Right to data portability
- Right to rectification of personal data
- Right to object to the collection, use, or disclosure of personal data
- Right to erasure or destruction or anonymization of personal data
- Right to restriction of personal data processing